

# EKSAMEN

**Emnekode:** ITF15019

**Emnenavn:** Innføring i datasikkerhet

**Dato:** 02/05-2024

**Eksamenstid:** 09.00-13.00, 4 timer + 15 minutter til klargjøring og innlevering av besvarelsen.

**Hjelpemidler:**

Ingen

**Faglærere:** Tom Heine Nätt og Ole-Edvard Ørebæk

## Om eksamensoppgaven:

Oppgavesettet består av **6** hovedoppgaver med hvert sitt overordnede tema og et antall deloppgaver. Det er angitt på hver hovedoppgave hvor mye denne i prosent teller av totalen. Vektingen av deloppgaver internt i en hovedoppgave vil reflektere omfanget av deloppgaven, men er ikke angitt eksplisitt.

Selv om hovedoppgavene har angitt en omtrentlig vekting, så er det viktig å påpeke at karakteren fastsettes basert på en helhetlig vurdering av besvarelsen.

NB! Sørg for å besvare deloppgavene separat, markert tydelig med bokstaven på deloppgaven du besvarer. Sensuren vil ikke "flytte svar" mellom deloppgaver eller hovedoppgaver der de virker å høre bedre hjemme. Besvar derfor heller ikke deloppgavene samlet slik som "a og b) ...".

For å forenkle sensuren, samt øke din egen struktur på svarene, er det en stor fordel å besvare flere av oppgavene som kulepunktlistene. Det er angitt spesielt der dette er forventet, men kan gjøres i de fleste oppgavene dersom du ønsker. Lag gjerne listene på følgende måte:

- **Oppsummert tittel:** Utdypende beskrivelse på en eller flere setninger
- **Oppsummert tittel:** Utdypende beskrivelse på en eller flere setninger

Gjør dine egne forutsetninger dersom du mener noe er uklart i oppgavene.

Takk for et hyggelig semester - beklager at vi har gjort dere paranoide...

**Lykke til!**

**Sensurfrist:** 28/05-2024

Karakterene blir tilgjengelige for studenter på Studentweb.

## <sup>1</sup> Oppgave 1 - Informasjonssikkerhet/Bedrifter - 20 %

- a) Forklar hva som menes med følgende sammenheng, og hvordan denne påvirker bedrifters sikkerhetsarbeid. (Konsekvens er også omtalt som tap i forelesningene):

**konsekvens \* sannsynlighet < kostnad av mottiltak**

- b) Hvordan påvirker GDPR sammenhengen beskrevet i deloppgave a)?
- c) Hvilke tre *sikkerhetstjenester* er sentrale i informasjonssikkerhet? Du trenger kun angi de tre begrepene, ikke noen forklaring.
- d) Hvilke generelle metoder har man for risikohåndtering (vi har omtalt fire i forelesningene)?
- e) Forklar forskjellen på begrepene *safety* og *security*.
- a) Sannsynlighet er sjansen for om en hendelse skjer, konsekvens er dårligere omdømme, økonomisk tap, økonomisk straff, fengselsstraff, osv. sammenhengen betyr at hvis sjansen for en hendelse er liten, konsekvensene er få/små og kostnaden for dem er mindre enn mottiltak, så vil man ikke iverksette mottiltakene.
- b) GDPR forstørker konsekvensene ved å gi større økonomisk straff, gi flere og større plikter, gi brukere mer rettigheter, osv., samt øke sannsynligheten ved å kreve internkontroll og ansvar, kreve at alle virksomheter i «kjeden» følger GDPR, kreve at personvern/informasjonssikkerhet integreres i systemet fra starten, osv. slik at kostnadene av mottiltakene virker rimeligere.
- c) Konfidensialitet, integritet, tilgjengelighet
- d) Redusere/behandle risiko (innføre tiltak).  
Akseptere risiko (leve med den).  
Overføre risiko (f.eks. forsikring eller outsourcing).  
Unngå risiko (slutte med aktiviteten som medfører risiko).
- e) Security: Beskyttelse mot tilsiktede hendelser (mennesker som vil skade systemet, f.eks. hackere).

Safety: Beskyttelse mot utilsiktede hendelser (teknisk svikt, naturkatastrofer, menneskelige feil) for å unngå skade på liv og helse.

---

Maks poeng: 20

## <sup>2</sup> Oppgave 2 - Skadevare - 15 %

- a) Forklar hva som kjennetegner skadevare av typen *virus*.
- b) Forklar hva som kjennetegner skadevare av typen *orm*.
- c) Forklar hva som kjennetegner skadevare av typen *trojaner*.
- d) Hvilke hovedmetoder finnes for deteksjon av skadevare? Forklar hver av de.
- a) Virus trenger en vert, f.eks. en .exe-fil, for å kjøre, men trenger manuell interaksjon for å spre seg.
- b) Ormer er et selvstendig program, er selv-replikerende og selv-spredende. De infiserer nettverk istedenfor maskiner.

- c) Trojanere gjemmer seg godt i legitime applikasjoner, helst i «må ha nå»-programmer som spill, spres gjennom nedlastning istedenfor automatisk og tar over/er 1 program.

d) Signaturbasert:

Sammenlikne deler av maskinkode som kjennetegner skadevaren.

Fordeler: rask, effektiv, «feilfritt», preventiv

Ulemper: oppdatere signaturfil, kartlegge skadevaren etter første angrep, dårlig mot meta-/polymorfistisk skadevare

Heuristikk:

Bruke parametere og grenseverdier for å finne om programmet er en skadevare.

Fordeler: finner «ukjente» skadevarer

Ulemper: falske positive, blir lett lurt

Anomalibasert:

Programmet sjekker om uvanlige handlinger/oppførsler, som økt temperatur, store endringer på filstørrelser, osv., skjer og varsler om man har skadevare. Likner på heuristikk.

Fordeler: finner «ukjente» skadevarer, tilpasser ditt normale arbeidsforhold, nettverk, osv., mindre avhengig av oppdateringer av skadevares oppbygning.

Ulemper: krever tid for å kjenne det normale, kan utnyttes for gradvis tilvenning av det normale

Snubletråder:

Programmet har en kopi av et bestemt program som den sammenlikner med senere endringer og varsler om endringer skjer.

Fordeler: effektiv, oppdager det usynlige som rootkits, pålitelig for om integritet er brutt, forteller man har skadevare.

Ulemper: falske positive, reaktiv

---

Maks poeng: 10

### **<sup>3</sup> Oppgave 3 - Kryptering - 15 %**

- a) Forklar forskjellen på krypteringsmetodene *shared key* (også kalt symmetrisk) og *public/private key* (også kalt asymmetrisk).
- b) Hvilke fordeler og ulemper har hver av disse metodene. Besvar oppgaven som firekulepunktliste (dvs. fordeler *shared key*, ulemper *shared key*, fordeler *public/private key*, ulemper *public/private key*)
- c) Forklar hvordan de to metodene kan kombineres for å dra nytte av fordelene til begge.

- a) *Shared key/symmetrisk*: en felles nøkkel som kan kryptere og dekryptere informasjon.  
*Public/private key / asymmetrisk*: en privat nøkkel som hemmeliggjøres og en offentlig nøkkel som deles med alle.

b) Symmetrisk

Fordeler:

- Hastighet
- Enkel
- effektiv

ulemper:

- vanskelig å skalere (flere brukere, flere unike nøkler)
- deling av nøkkel.
- Blir nøkkelen lekket/stjålet blir informasjonen kjent

#### Asymmetrisk

Fordeler:

- Sikker og enkel deling av nøkler (en offentlig og en privat)
- Vanskelig å knekke
- Troverdighet (identifisering gjennom signatur og autentisering)

Ulemper:

- Ineffektiv
- Treg
- Ressurskrevende

- c) For å få fordelene av å kombinere metodene kan man først bruke symmetrisk metode for å kryptere informasjonen. Deretter bruke asymmetrisk metode for å dele nøkkelen til informasjonen. Dette skjer ved at senderen og mottakeren blir enig om en krypteringsalgoritme. Deretter lages en privat nøkkel som består av 2 primtall, som bare mottakeren vet, og en offentlig som består av produktet til primtallene, som alle vet. Deretter bruker senderen den offentlige nøkkelen til å kryptere fellesnøkkelen. Så vil senderen sende den krypterte fellesnøkkelen og mottakeren bruker sin private nøkkel for å dekryptere fellesnøkkelen. Til slutt vil partene bruke fellesnøkkelen for å kommunisere videre.

---

Maks poeng: 10

## **4 Oppgave 4 - Nettverk - 20 %**

- a) Hva kan en angriper oppnå ved å få en bruker til å koble til et trådløst nett (trådløs basestasjon) som angriperen drifter? (Her er det flere momenter å trekke frem, svar som kulepunkter)
- b) Forklar hvorfor det ikke nødvendigvis er trygt å koble til et trådløst nett med et nettverksnavn (SSID) som du kjenner.
- c) Forklar hvordan og hvorfor VPN kan gjøre en nettverksforbindelse sikrere.
- d) Finnes det farer eller ulemper ved VPN?
- a) \* økonomisk vinning (selge din data)
- Phishing (identitetstyveri)
  - Dns-manipulasjon
  - Overvåking/avlytting
  - Sensur
  - Politisk vinning (utpressing, «blackmailing», endre ens syn på en stat, osv.)
- b) Fordi angriperen kan bruke en basestasjon med samme nettverksnavn med sterkere signal rettet mot offeret, slik at offeret kobles til basestasjonen og gjøre hva enn de vil.
- c) Hvordan: brukeren sender en forespørsel til ISP om å videresende den egentlige forespørselen til en VPN-server. Deretter vil VPN-serveren motta forespørselen og tilbakesender nettsiden til ISP, som igjen videresender til brukeren.
- Hvorfor: hele trafikken er kryptert, slik at ISP bare ser hvor trafikken skal videresendes. IP-adresse til nettsider blir kryptert og DNS-oppslag håndteres av VPN-tjenesten.

- d) Minket hastighet, falsk trygghet (beskytter ikke mot nedlastning av skadevare, klikking av lenker, innlogging i tjenester), flytte tillit (håpe på at de ikke logger trafikken din, gi din data til myndigheter, osv.), «gratis» (du er produktet. kan selge din data), blokkert fra tjenester (banker, strømnetjenester, osv., minste tilgang til konto, osv.), myndigheter kan kreve innsikt i logger, kan bli hacket selv,

---

Maks poeng: 10

## 5 Oppgave 5 - Web - 20 %

- a) Forklar hva *sesjonskapring* (*session hijacking*) er.
- b) Forklar ulike generelle fremgangsmåter som benyttes for å kapre en sesjon.
- c) Hvilke tiltak kan en bruker gjøre for å redusere risikoen for, og konsekvensene av, en sesjonskapring.
- d) Forklar hva *CSRF* (Cross Site Request Forgery / webtrojaner) er.
- a) Sesjonskapring er når en angriper oppnår uautorisert tilgang til dine sesjoner/økter, f.eks. sesjon-id for lagret innlogging, og dermed har offerets lagret informasjon og aktivitet.
- b) Man-in-the-middle-angrep (motta og videresende cookies og informasjon mellom brukeren og tjenesten), CSS/XSS (klikke på en lenke som sender cookies og veldig fort laste inn brukerens ønsket nettside), pakkesniffing (avlytte trafikken mellom bruker og tjenesten og kopiere økt-id-ene), X-CSRF,
- c) Logge av ved ferdig økt, bruke 2-/MFA, ikke dele cookies, unngå åpne wifi (spesielt når man allerede identifiserte seg/er logget inn), bruke HTTPS.
- d) Send kommandoer via pålitelig bruker til nettsider/apper som stoler på brukeren, altså late som om man er en legitim bruker. Angriperen antar at brukeren(e) allerede identifiserte seg. F.eks. gjennom en skjult/manipulert lenke eller i en img-tag.

---

Maks poeng: 10

## 6 Oppgave 6 - Trusselbildet - 10 %

- a) Forklar hvordan angriperens ønske om økonomisk vinning (motivasjon) har påvirket trusselbildet de senere årene.
- b) Forklar hvordan sosial manipulasjon har påvirket trusselbildet de senere årene.

Trusselbildet = Situasjonen rundt datasikkerhet; Hvem er angripere, hva er motivasjonen, hvilke ressurser og kunnskap har de, hvilke teknikker benyttes, hvem er målene osv.

Besvar deloppgavene som kulepunktliste der hvert moment du vil trekke frem er ett kulepunkt.

- a) \* utnyttelse av infrastruktur: angriperstater kan f.eks. bruke super-ormer/-virus for å ødelegge andre staters infrastruktur og dermed medføre økonomisk nedgang/tap. Dette kan føre til at angriperstaten(e) får mer etterspørsel av ressurser av/kunnskap for slike infrastrukturer eller materialer.
- Industriell spionasje: aktører som kommersielle aktører kan dele/selge data/tilgang til data med myndigheter, databrokers, individer, osv.. for å spare på utviklingskostnader og svekke konkurranse.
- b) \* Tillitssvekking/-styrking: få andre til å følge dine ondskapsfull ordre mens man utgir seg som myndigheten, som fører til myndigheten mister tillit og befolkningen styrker tillit til angriperen og angriperen kan tilby tjenester som befolkningen frivillig gir fra seg data til.
- Menneskelig sårbarhet: «hacke» mennesker gjennom phishing, vishing og smishing for å f.eks. endre syn på en aktør eller ufrivillig gi fra seg sensitiv informasjon.
-





